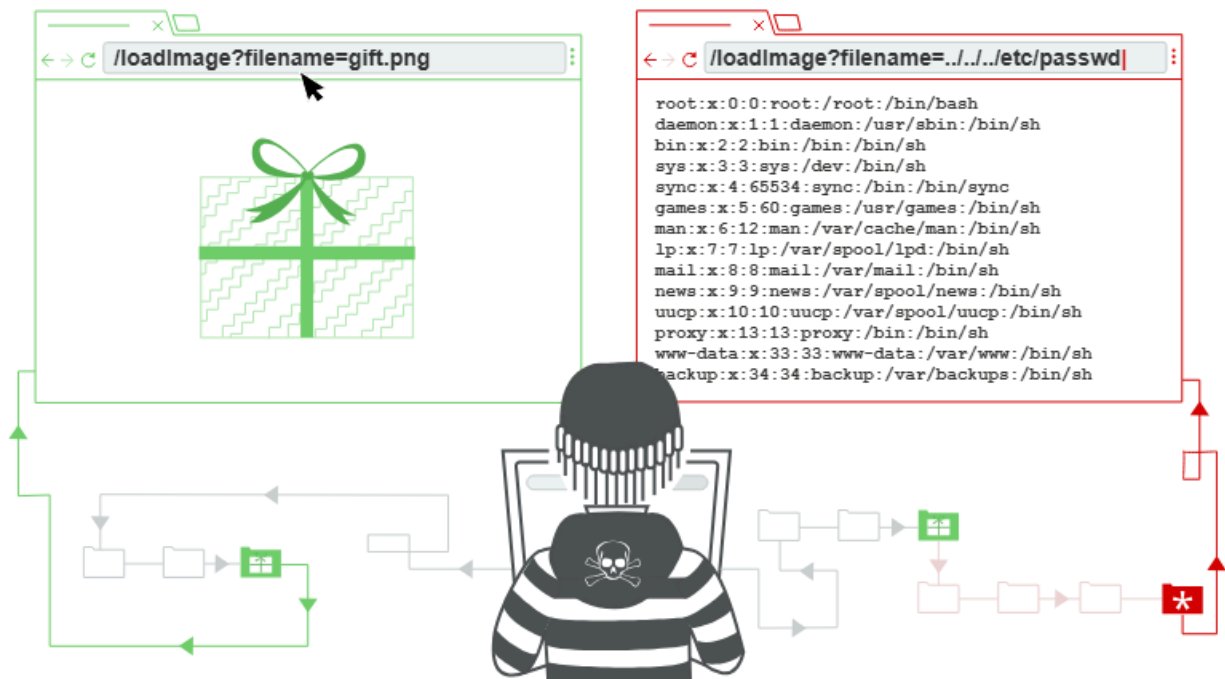


Path Traversal

I. Giới thiệu chung

- **Path Traversal** (hay **Directory Traversal**) là một lỗ hổng bảo mật phổ biến trên các ứng dụng web. Lỗ hổng này cho phép kẻ tấn công truy cập vào các tệp tin và thư mục trên máy chủ mà không được cấp quyền hợp lệ. Thay vì chỉ được truy cập vào các tệp hoặc thư mục hợp pháp của ứng dụng, kẻ tấn công có thể điều hướng qua các đường dẫn và truy xuất các tệp hệ thống quan trọng như `/etc/passwd` trên hệ thống Linux hoặc `C:\Windows\system.ini` trên Windows.
- Lỗ hổng này thường xảy ra khi ứng dụng web không kiểm tra đúng cách đầu vào từ người dùng, cho phép kẻ tấn công sử dụng các chuỗi như `../` để điều hướng lên các thư mục cấp cao hơn trong hệ thống tệp.



II. Tấn công Path traversal

Một ví dụ minh họa về cuộc tấn công Path Traversal:

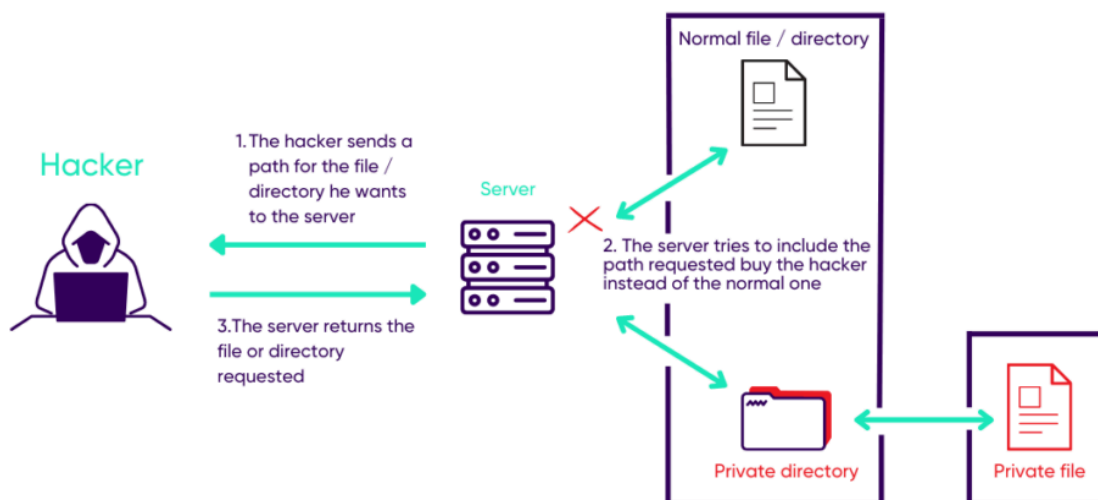
- Giả sử một ứng dụng web có URL như sau:

`http://example.com/download?file=report.pdf`

- Nếu ứng dụng không kiểm tra kỹ đầu vào, kẻ tấn công có thể thay đổi tham số file để truy cập tệp khác ngoài **report.pdf**, ví dụ:

`http://example.com/download?file=../../etc/passwd`

- Ở đây, chuỗi `../` giúp kẻ tấn công di chuyển lên các thư mục cấp cao hơn và truy cập tệp nhạy cảm như **`/etc/passwd`** trên máy chủ Linux, chứa thông tin tài khoản người dùng. Nếu ứng dụng không được bảo vệ, kẻ tấn công có thể đọc các tệp hệ thống mà họ không được phép truy cập.



III. Cách phòng chống Path travelsal

- Nên validate input của người dùng : Đảm bảo rằng tất cả dữ liệu đầu vào của người dùng đều được kiểm tra trước khi sử dụng, đặc biệt là các ký tự đặc biệt như `"../"` .
- Sử dụng whitelist: Chỉ cho phép người dùng truy cập các tệp hoặc thư mục hợp lệ bằng cách sử dụng danh sách trắng (whitelist) các đường dẫn được phép.
- Hạn chế quyền truy cập tệp: Cấu hình đúng các quyền truy cập tệp và thư mục trên máy chủ để hạn chế truy cập không mong muốn.



- Không dựa vào tên tệp do người dùng cung cấp: Hạn chế việc cho phép người dùng chỉ định tên tệp, thay vào đó sử dụng ID hoặc token để truy xuất tệp an toàn.
- Kiểm tra và bảo vệ ứng dụng thường xuyên: Sử dụng các công cụ kiểm tra bảo mật và các phương pháp phát hiện để bảo vệ ứng dụng khỏi lỗ hổng này.

IV. Nguồn tham khảo

- <https://viblo.asia/p/tan-cong-path-traversal-va-cach-thuc-phong-thu-bJzKmO7w19N>
- <https://techmaster.vn/posts/37086/nhan-dien-va-bao-ve-laravel-path-traversal>
- <https://portswigger.net/web-security/file-path-traversal>
- https://owasp.org/www-community/attacks/Path_Traversal

Mọi thắc mắc hay ý kiến đóng góp vui lòng liên hệ :

Email : r3dctf.info@gmail.com

@Design by R3D CTF Team